Assignment 6

Name: Sai Aditya | Task: Improper Session Management

Objective

Identify and demonstrate an improper session-management flaw in the assigned TuteDude TryHackMe web application by examining client-side information, logging in with the lab credentials, and testing how the application handles user roles.

Methodology

1. Opened the assigned lab target at `http://192.168.31.236` on port 80, as directed by the room instructions.

2. Inspected the login page source and found an HTML comment containing the lab's initial login credentials. Used those credentials to sign in as John.

3. Opened Firefox Developer Tools and inspected the site's cookies. The cookie named `user_role` was set to `employee`, indicating that role information was exposed to client-side manipulation.

4. Changed the role value to `admin` and refreshed the dashboard. The application displayed a privilege-escalation alert and the flag shown in the evidence.

Result

Flag captured:

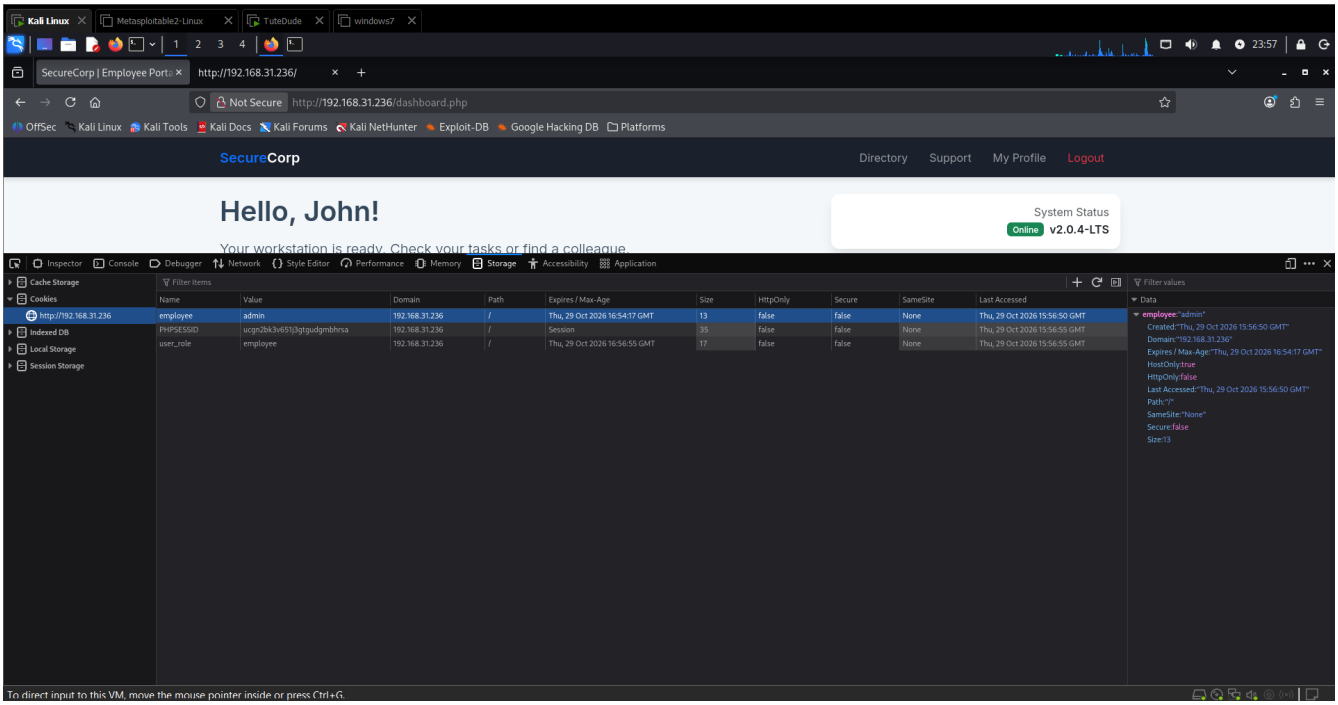
```
FLAG{COOKIE_MANIPULATION_SUCCESS}
```

The flag was submitted to the TryHackMe question and accepted, as shown in the final verification screenshot. This result demonstrates that authorization decisions should be enforced server-side rather than trusted from a client-controlled role cookie.

Evidence included

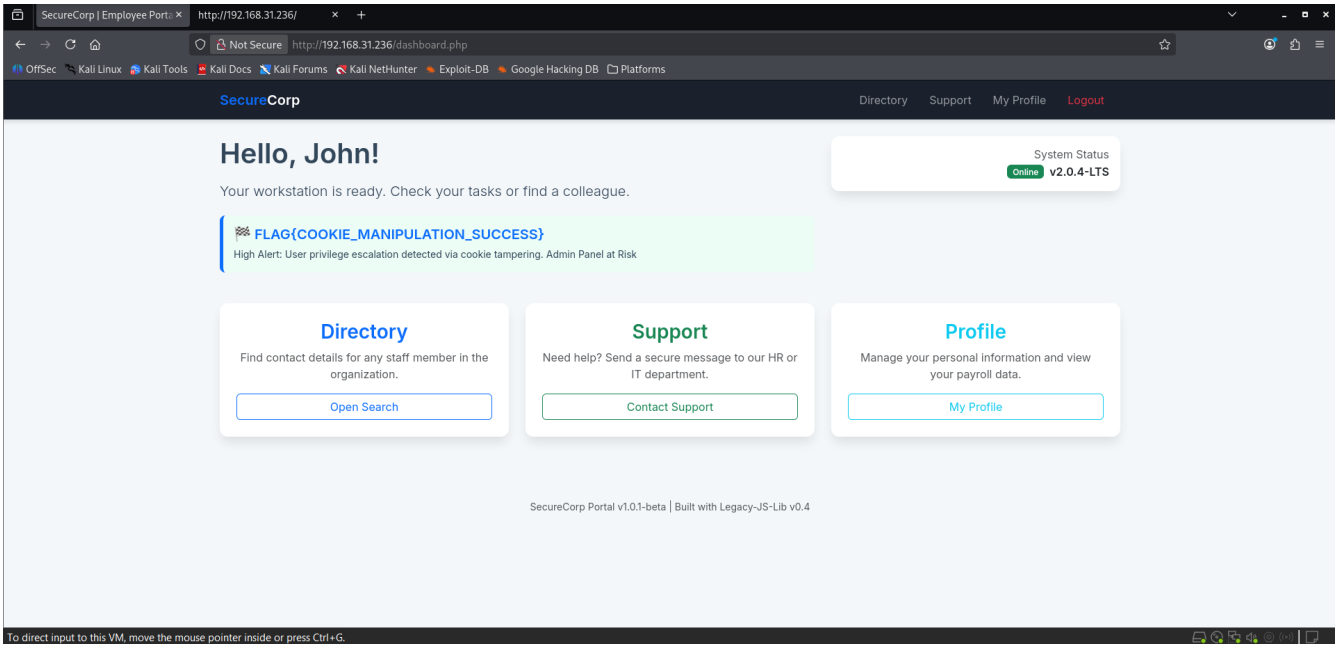
The following pages contain screenshots of the cookie inspection, the dashboard displaying the captured flag, and the TryHackMe confirmation showing the answer was accepted.

Evidence 1 — Cookie Inspection



Firefox Storage panel showing the session cookie and role-related cookie during testing.

Evidence 2 — Flag Displayed on Dashboard



The dashboard displays FLAG{COOKIE_MANIPULATION_SUCCESS} and identifies cookie tampering as the privilege-escalation issue.

Evidence 3 — TryHackMe Verification



TryHackMe confirms the submitted flag with a green “Correct Answer” status.